

INSTITUTO FEDERAL
Acre

Curso Superior de Tecnologia em Sistemas para Internet
Disciplina: Governança de Tecnologia da Informação
Turma: CSTSI 6 – 2026.2
Equipe 03

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO (PSI)
PREFEITURA DE BOA ESPERANÇA

Rio Branco – AC
2026

1. Objetivo e escopo

Esta PSI define as regras mínimas para proteger a confidencialidade, a integridade e a disponibilidade das informações da Prefeitura de Boa Esperança. Ela transforma em diretrizes obrigatórias as políticas P1 a P4 propostas na Seção 6 do PDTI.

Aplica-se a todos os servidores, estagiários, prestadores de serviço e fornecedores que acessem informações ou recursos de TI da Prefeitura. Abrange, prioritariamente, o portal institucional, o sistema de prontuário eletrônico, os bancos de dados críticos, as rotinas de backup e a rede que conecta as unidades de saúde (UBS). Demais sistemas seguem esta PSI no que couber e serão detalhados em revisões futuras.

2. Princípios de segurança da informação

- **Confidencialidade:** a informação só é acessada por quem tem necessidade funcional, com atenção especial aos dados de saúde do prontuário.
- **Integridade:** dados e cópias de segurança devem permanecer corretos e completos, comprovados por testes de restauração.
- **Disponibilidade:** serviços críticos devem estar acessíveis quando necessários, com meta de 99% mensal para o portal.
- **Menor privilégio e necessidade de conhecer:** cada usuário recebe apenas os acessos indispensáveis à sua função.
- **Rastreabilidade:** acessos, mudanças, incidentes e testes devem gerar registros verificáveis.
- **Prevenção e melhoria contínua:** riscos são tratados antes que se tornem incidentes e os controles são revisados a partir dos indicadores do PDTI.

3. Papéis e responsabilidades

Os papéis seguem os responsáveis funcionais já propostos no PDTI e deverão ser confirmados conforme a estrutura administrativa da Prefeitura.

- **Instância de governança da Prefeitura:** aprova esta PSI, recebe os relatórios de acompanhamento e decide sobre riscos residuais altos.
- **Gestão de TI:** coordena a PSI, gere SLA e continuidade do portal, consolida indicadores, registra incidentes e justifica a aceitação de riscos.

- **Equipe de Sistemas e Infraestrutura:** opera o prontuário e a rede, controla mudanças, monitora desempenho e aplica as permissões de acesso.
- **Equipe de Infraestrutura de TI:** executa e monitora backups, protege os repositórios de cópias e realiza os testes de restauração.
- **Gestores das secretarias e unidades:** solicitam e revisam os acessos de suas equipes e definem a classificação das informações sob sua guarda.
- **Usuários (servidores, estagiários, terceiros):** cumprem esta PSI, protegem suas credenciais e comunicam incidentes imediatamente.
- **Fornecedores e prestadores:** cumprem as cláusulas de SLA, segurança e confidencialidade previstas em contrato.

4. Classificação das informações

Toda informação deve receber um dos três níveis abaixo; na dúvida, adota-se o nível mais restritivo.

Nível	Descrição	Exemplos	Tratamento mínimo
Pública	Pode ser divulgada sem restrição	Conteúdo do portal, dados de transparência	Garantir integridade e autoria da publicação
Interna	Uso restrito ao funcionamento da Prefeitura	Contratos, procedimentos de TI, registros de chamados	Acesso apenas a servidores e terceiros autorizados
Restrita	Dados pessoais e sensíveis ou críticos à continuidade	Prontuários, cópias de backup, credenciais, logs de acesso	Acesso por função, registro de acessos, cópia protegida e testada

A classificação é definida pelo gestor da unidade responsável pela informação, com apoio da Gestão de TI.

5. Controle de acesso e uso aceitável

O acesso é concedido por função, mediante solicitação do gestor da unidade, e revogado no desligamento ou na mudança de função (política P4 do PDTI).

- Cada usuário possui credencial individual e intransferível; contas compartilhadas são proibidas.
- Acessos ao prontuário e aos repositórios de backup são restritos a perfis autorizados e registrados em log.
- As permissões são revisadas periodicamente pela Gestão de TI com os gestores das unidades.

- Contas administrativas são usadas apenas para tarefas administrativas.

Uso aceitável: os recursos de TI destinam-se às atividades institucionais. É vedado divulgar dados restritos, instalar software não autorizado, contornar controles de segurança ou copiar dados de pacientes para mídias e serviços pessoais. O tráfego do prontuário tem prioridade na rede das UBS (QoS).

6. Incidentes, privacidade e continuidade

Incidentes: qualquer queda de serviço, falha de backup, acesso indevido ou suspeita de vazamento deve ser comunicada imediatamente à Gestão de TI. Cada incidente é registrado com causa, impacto, ações e responsável, seguindo o escalonamento definido no plano de recuperação do portal.

Privacidade: dados pessoais, em especial os de saúde, são tratados conforme a LGPD (Lei nº 13.709/2018), apenas para finalidades institucionais e com o mínimo de acesso necessário. Incidentes com dados pessoais são avaliados quanto à comunicação aos titulares e à autoridade competente.

Continuidade:

- O portal deve ter SLA formal, monitoramento contínuo e plano de recuperação com meta de restauração em até 4 horas (P1).
- Mudanças no prontuário são testadas antes da implantação e preveem reversão (P2).
- Backups seguem a regra 3-2-1, são automatizados, notificam falhas e passam por teste formal de restauração mensal, com o primeiro até o mês 4 (P3).

7. Conformidade, revisão e aprovação

A conformidade é demonstrada por evidências: SLA formalizado, relatórios de disponibilidade, registros de mudanças, logs de backup, relatórios de testes de restauração e revisões de permissões. O descumprimento desta PSI será apurado conforme as normas disciplinares e contratuais aplicáveis.

A PSI é revisada anualmente, junto com o PDTI, ou antes disso após incidente grave, teste de restauração malsucedido, mudança relevante no ambiente ou alteração contratual. A Gestão de TI propõe as revisões e a instância de governança da Prefeitura as aprova.

Pendências de validação: confirmação da instância aprovadora, das normas aplicáveis além da LGPD e da metodologia oficial de classificação de riscos.

8. Relação com o PDTI

Cada diretriz desta PSI responde a um problema, objetivo e risco do PDTI; os indicadores do PDTI também medem a efetividade da PSI.

Problema do PDTI	Objetivo / Iniciativa	Riscos	Diretriz da PSI	Indicador e meta
Portal indisponível por 19 h em um mês	O1 / I1	R1, R2	P1 – SLA, monitoramento e recuperação (seção 6)	Disponibilidade ≥ 99% ao mês
Prontuário lento em 7 de 20 dias úteis, 146 chamados	O2 / I2	R3, R4, R5	P2 – gestão de mudanças e desempenho (seção 6)	Redução de 80% dos chamados em 6 meses
Backup parcialmente manual, último teste há 11 meses	O3 / I3	R6, R7	P3 – backup 3-2-1 e testes mensais (seção 6)	100% dos testes previstos em 12 meses
Dados sensíveis do prontuário e das cópias	O2, O3 / I2, I3	R8	P4 – controle de acesso e LGPD (seções 4 e 5)	Revisões de permissões registradas

9. Matriz resumida de responsabilidades

Legenda: R = executa · A = aprova/responde · C = consultado · I = informado.

Atividade	Governança	Gestão de TI	Sistemas e Infraestrutura	Infraestrutura de TI	Gestores das unidades	Usuários
Aprovar e revisar a PSI	A	R	C	C	C	I
SLA e continuidade do portal	I	A/R	C	C	I	I
Desempenho e mudanças do prontuário	I	A	R	C	C	I
Backup e testes de restauração	I	A	C	R	I	-
Concessão e revisão de acessos	-	A	R	R	C	I
Classificação das informações	-	C	-	-	A/R	I
Registro e resposta a incidentes	I	A	R	R	C	R (comunica)
Indicadores e relatório mensal	I	A/R	R	R	-	-